



ZAP by
Checkmarx

ZAP by Checkmarx Scanning Report 5/18/26 - railway

Site: <https://web-dev-1-production.up.railway.app>

Generated on Mon, 18 May 2026 01:54:54

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	2
Low	2
Informational	2
False Positives:	0

Insights

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP warnings logged - see the zap. log file for details	30
Info	Informational	https://web-dev-1-production.up.railway.app	Percentage of responses with status code 2xx	88 %
Info	Informational	https://web-dev-1-production.up.railway.app	Percentage of responses with status code 3xx	11 %
Info	Informational	https://web-dev-1-production.up.railway.app	Percentage of endpoints with content type application/javascript	16 %
Info	Informational	https://web-dev-1-production.up.railway.app	Percentage of endpoints with content	16 %

		production. up.railway. app	type image /svg+xml	
Info	Informational	https://web-dev-1-production. up.railway. app	Percentage of endpoints with content type text/css	16 %
Info	Informational	https://web-dev-1-production. up.railway. app	Percentage of endpoints with content type text/html	50 %
Info	Informational	https://web-dev-1-production. up.railway. app	Percentage of endpoints with method GET	100 %
Info	Informational	https://web-dev-1-production. up.railway. app	Count of total endpoints	6
Info	Informational	https://web-dev-1-production. up.railway. app	Percentage of slow responses	100 %

Alerts

Name	Risk Level	Number of Instances
Content Security Policy (CSP) Header Not Set	Medium	3
Missing Anti-clickjacking Header	Medium	3
Strict-Transport-Security Header Not Set	Low	Systemic
X-Content-Type-Options Header Missing	Low	Systemic
Modern Web Application	Informational	3
Re-examine Cache-control Directives	Informational	3

Alert Detail

Medium	Content Security Policy (CSP) Header Not Set
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	https://web-dev-1-production.up.railway.app/

Node Name	https://web-dev-1-production.up.railway.app/
Method	GET
Attack	
Evidence	
Other Info	
URL	https://web-dev-1-production.up.railway.app/robots.txt
Node Name	https://web-dev-1-production.up.railway.app/robots.txt
Method	GET
Attack	
Evidence	
Other Info	
URL	https://web-dev-1-production.up.railway.app/sitemap.xml
Node Name	https://web-dev-1-production.up.railway.app/sitemap.xml
Method	GET
Attack	
Evidence	
Other Info	
Instances	3
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/
CWE Id	693
WASC Id	15
Plugin Id	10038

Medium	Missing Anti-clickjacking Header
Description	The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.
URL	https://web-dev-1-production.up.railway.app/
Node Name	https://web-dev-1-production.up.railway.app/
Method	GET
Attack	
Evidence	
Other	

Info	
URL	https://web-dev-1-production.up.railway.app/robots.txt
Node Name	https://web-dev-1-production.up.railway.app/robots.txt
Method	GET
Attack	
Evidence	
Other Info	
URL	https://web-dev-1-production.up.railway.app/sitemap.xml
Node Name	https://web-dev-1-production.up.railway.app/sitemap.xml
Method	GET
Attack	
Evidence	
Other Info	
Instances	3
Solution	Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app. If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
CWE Id	1021
WASC Id	15
Plugin Id	10020

Low	Strict-Transport-Security Header Not Set
Description	HTTP Strict Transport Security (HSTS) is a web security policy mechanism whereby a web server declares that complying user agents (such as a web browser) are to interact with it using only secure HTTPS connections (i.e. HTTP layered over TLS/SSL). HSTS is an IETF standards track protocol and is specified in RFC 6797.
URL	https://web-dev-1-production.up.railway.app/
Node Name	https://web-dev-1-production.up.railway.app/
Method	GET
Attack	
Evidence	
Other Info	
URL	https://web-dev-1-production.up.railway.app/assets/index-CorEGhm_.css
Node Name	https://web-dev-1-production.up.railway.app/assets/index-CorEGhm_.css
Method	GET
Attack	

Evidence	
Other Info	
URL	https://web-dev-1-production.up.railway.app/robots.txt
Node Name	https://web-dev-1-production.up.railway.app/robots.txt
Method	GET
Attack	
Evidence	
Other Info	
URL	https://web-dev-1-production.up.railway.app/sitemap.xml
Node Name	https://web-dev-1-production.up.railway.app/sitemap.xml
Method	GET
Attack	
Evidence	
Other Info	
URL	https://web-dev-1-production.up.railway.app/vite.svg
Node Name	https://web-dev-1-production.up.railway.app/vite.svg
Method	GET
Attack	
Evidence	
Other Info	
Instances	Systemic
Solution	Ensure that your web server, application server, load balancer, etc. is configured to enforce Strict-Transport-Security.
Reference	https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet.html https://owasp.org/www-community/Security-Headers https://en.wikipedia.org/wiki/HTTP_Strict_Transport_Security https://caniuse.com/stricttransportsecurity https://datatracker.ietf.org/doc/html/rfc6797
CWE Id	319
WASC Id	15
Plugin Id	10035

Low	X-Content-Type-Options Header Missing
Description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
URL	https://web-dev-1-production.up.railway.app/
Node Name	https://web-dev-1-production.up.railway.app/

Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://web-dev-1-production.up.railway.app/assets/index-CorEGhm_.css
Node Name	https://web-dev-1-production.up.railway.app/assets/index-CorEGhm_.css
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://web-dev-1-production.up.railway.app/robots.txt
Node Name	https://web-dev-1-production.up.railway.app/robots.txt
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://web-dev-1-production.up.railway.app/sitemap.xml
Node Name	https://web-dev-1-production.up.railway.app/sitemap.xml
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://web-dev-1-production.up.railway.app/vite.svg
Node Name	https://web-dev-1-production.up.railway.app/vite.svg
Method	GET
Attack	
Evidence	
Other	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type.

Info	At "High" threshold this scan rule will not alert on client or server error responses.
Instances	Systemic
Solution	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application /web server to not perform MIME-sniffing.
Reference	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security_Headers
CWE Id	693
WASC Id	15
Plugin Id	10021

Informational	Modern Web Application
Description	The application appears to be a modern web application. If you need to explore it automatically then the Ajax Spider may well be more effective than the standard one.
URL	https://web-dev-1-production.up.railway.app/
Node Name	https://web-dev-1-production.up.railway.app/
Method	GET
Attack	
Evidence	<script type="module" crossorigin src="/assets/index-DnJ3dKtq.js"></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	https://web-dev-1-production.up.railway.app/robots.txt
Node Name	https://web-dev-1-production.up.railway.app/robots.txt
Method	GET
Attack	
Evidence	<script type="module" crossorigin src="/assets/index-DnJ3dKtq.js"></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	https://web-dev-1-production.up.railway.app/sitemap.xml
Node Name	https://web-dev-1-production.up.railway.app/sitemap.xml
Method	GET
Attack	
Evidence	<script type="module" crossorigin src="/assets/index-DnJ3dKtq.js"></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
Instances	3
Solution	This is an informational alert and so no changes are required.
Reference	
CWE Id	
WASC Id	

Plugin Id	10109
Informational	Re-examine Cache-control Directives
Description	The cache-control header has not been set properly or is missing, allowing the browser and proxies to cache content. For static assets like css, js, or image files this might be intended, however, the resources should be reviewed to ensure that no sensitive content will be cached.
URL	https://web-dev-1-production.up.railway.app/
Node Name	https://web-dev-1-production.up.railway.app/
Method	GET
Attack	
Evidence	
Other Info	
URL	https://web-dev-1-production.up.railway.app/robots.txt
Node Name	https://web-dev-1-production.up.railway.app/robots.txt
Method	GET
Attack	
Evidence	
Other Info	
URL	https://web-dev-1-production.up.railway.app/sitemap.xml
Node Name	https://web-dev-1-production.up.railway.app/sitemap.xml
Method	GET
Attack	
Evidence	
Other Info	
Instances	3
Solution	For secure content, ensure the cache-control HTTP header is set with "no-cache, no-store, must-revalidate". If an asset should be cached consider setting the directives "public, max-age, immutable".
Reference	https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html#web-content-caching https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cache-Control https://grayduck.mn/2021/09/13/cache-control-recommendations/
CWE Id	525
WASC Id	13
Plugin Id	10015